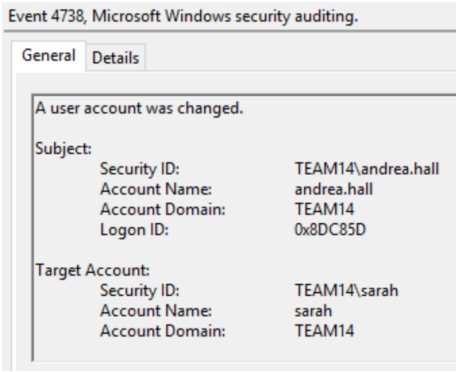
12:30 PM INTRUSION REPORT

Team #14: Kansas State HackCats

Intrusion Reports

Active Directory

At **11:20am** there was activity from the user account andrea.hall that was creating accounts and changing groups. This was observed through Event Viewer.



Event 4738, Microsoft Windows security auditing.

General | Details

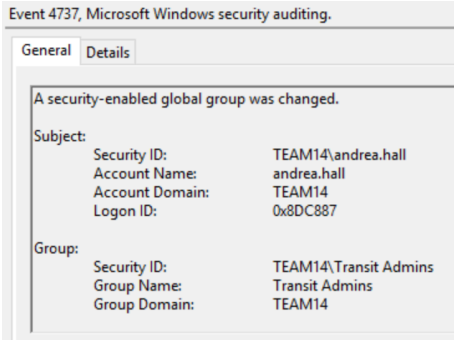
A user account was changed.

Subject:

Security ID:	TEAM14\andrea.hall
Account Name:	andrea.hall
Account Domain:	TEAM14
Logon ID:	0x8DC85D

Target Account:

Security ID:	TEAM14\sarah
Account Name:	sarah
Account Domain:	TEAM14



Event 4737, Microsoft Windows security auditing.

General | Details

A security-enabled global group was changed.

Subject:

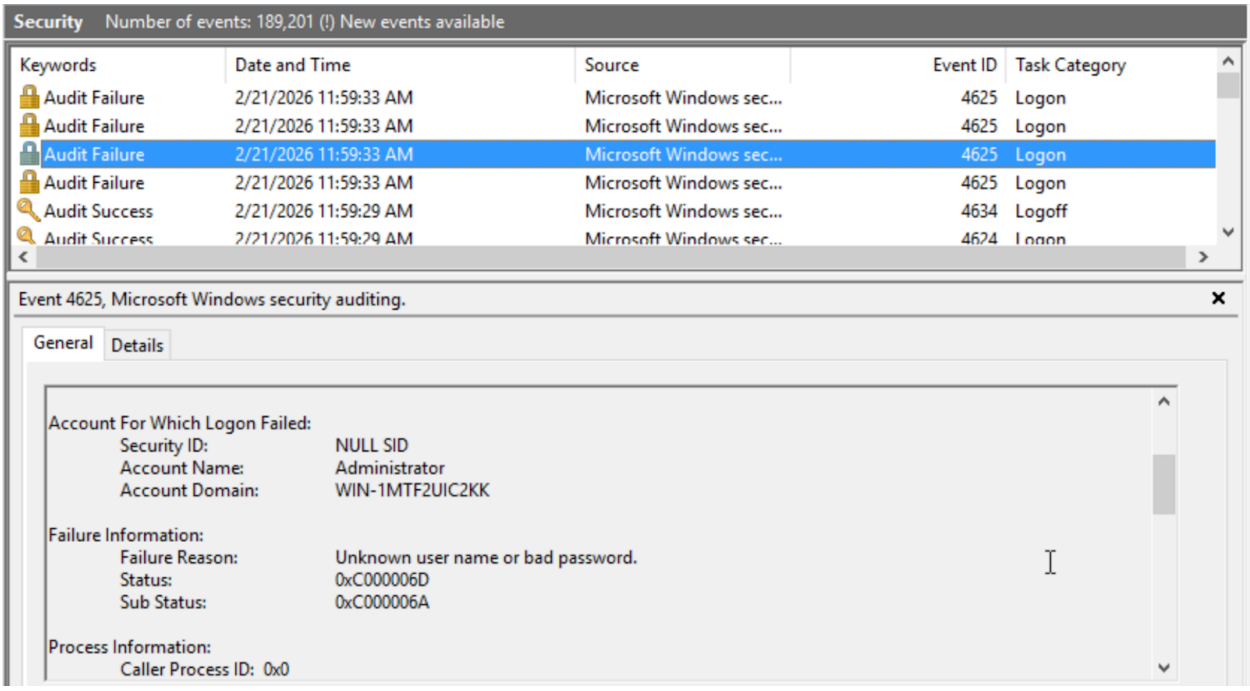
Security ID:	TEAM14\andrea.hall
Account Name:	andrea.hall
Account Domain:	TEAM14
Logon ID:	0x8DC887

Group:

Security ID:	TEAM14\Transit Admins
Group Name:	Transit Admins
Group Domain:	TEAM14

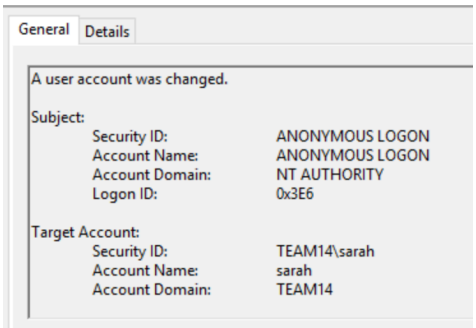
The andrea.hall account created account ‘sarah’ and added the account to the Transit Admins group.

At around **12:00pm** someone from outside our team was attempting to log in to Tickets.



This user was not allowed to log in and our group policy rules for user lockout kicked in after 5 failed attempts.

At **12:16pm** an ANONYMOUS LOGON account made changes to the ‘sarah’ account. This is under further investigation for if this was malicious.



Ticketing

There were multiple attempts to sign an invalid ticket using an excessive value for the validUntil parameter. These requests were blocked by the ticketing application thanks to our improved code.

```
      Hosting environment: Development
info: Microsoft.Hosting.Lifetime[0]
      Content root path: C:\Users\Administrator\Desktop\tickets
dbug: Microsoft.AspNetCore.Watch.BrowserRefresh.BrowserRefreshMiddleware[1]
      Response markup is scheduled to include browser refresh script injection.
dbug: Microsoft.AspNetCore.Watch.BrowserRefresh.BrowserRefreshMiddleware[2]
      Response markup was updated to include browser refresh script injection.
dbug: Microsoft.AspNetCore.Watch.BrowserRefresh.BrowserScriptMiddleware[0]
      Script injected: /_framework/aspnetcore-browser-refresh.js
fail: tickets.Controllers.TicketsController[0]
      Signing failed
      System.ArgumentException: validUntil exeeds the maximum limit
         at tickets.Services.TicketSigner.SignAsync(String subject, Int64 validFrom, Int64 validUntil) in C:\Users\Administrator\Desktop\tickets\Services\Tic
ketSigner.cs:line 21
         at tickets.Controllers.TicketsController.Sign(SignRequest req) in C:\Users\Administrator\Desktop\tickets\Controllers\TicketsController.cs:line 37
fail: tickets.Controllers.TicketsController[0]
      Signing failed
      System.ArgumentException: validUntil exeeds the maximum limit
         at tickets.Services.TicketSigner.SignAsync(String subject, Int64 validFrom, Int64 validUntil) in C:\Users\Administrator\Desktop\tickets\Services\Tic
ketSigner.cs:line 21
         at tickets.Controllers.TicketsController.Sign(SignRequest req) in C:\Users\Administrator\Desktop\tickets\Controllers\TicketsController.cs:line 37
fail: tickets.Controllers.TicketsController[0]
      Signing failed
      System.ArgumentException: validUntil exeeds the maximum limit
         at tickets.Services.TicketSigner.SignAsync(String subject, Int64 validFrom, Int64 validUntil) in C:\Users\Administrator\Desktop\tickets\Services\Tic
ketSigner.cs:line 21
         at tickets.Controllers.TicketsController.Sign(SignRequest req) in C:\Users\Administrator\Desktop\tickets\Controllers\TicketsController.cs:line 37
```

Management

We noted a vulnerability in the Management machine that could allow the red team to retrieve our management Database Read flag because. We had an insecure SECRET_KEY variable in the config file of the management backend. This could let someone forage a cookie to ‘log in’ as the blue_flag user, thus getting the flag. Knowing the secret key could allow them to falsely sign the cookie and make it look legit.

Admin

We noted a second denial-of-service style attack that occurred at 11:20. This attack originated from the a similar IP address as before, 12.110.206.222. Due to the safeguards that were put in place at the machine level, this IP was cut off after making about 25 attempts and no damage was done to the server.

1415	11:20:39.689081	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1462	11:20:40.676244	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1505	11:20:41.692323	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1549	11:20:42.690535	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1595	11:20:43.424314	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1649	11:20:44.704271	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1691	11:20:45.435866	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1737	11:20:46.704761	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1779	11:20:47.424182	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1826	11:20:48.687693	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1881	11:20:49.692489	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1
1929	11:20:50.691887	12.110.206.222	192.168.1.40	HTTP	464 GET /api/vehicles HTTP/1.1

Web Server

At approximately 7am, the web application hosted by the Web Server machine was exploited via command injection, leading to the discovery and loss of the /etc flag. This attack targeted the ticketmon service.

```
Feb 21 08:00:55 www ticketmon[53641]: <HTML>
Feb 21 08:00:55 www ticketmon[53641]: <HEAD>
Feb 21 08:00:55 www ticketmon[53641]: <TITLE>Directory /</TITLE>
Feb 21 08:00:55 www ticketmon[53641]: <BASE HREF="file:/">
Feb 21 08:00:55 www ticketmon[53641]: </HEAD>
Feb 21 08:00:55 www ticketmon[53641]: <BODY>
Feb 21 08:00:55 www ticketmon[53641]: <H1>Directory listing of /</H1>
Feb 21 08:00:55 www ticketmon[53641]: <UL>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="./">./</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="../">../</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF=".autorelabel">.autorelabel</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="afs/">afs/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="bin/">bin/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="boot/">boot/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="dev/">dev/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="d%A6%8E%DC8%08%13%02%13%03%13%01%FF%01%01%AB">d&brvbar;&#142;&Uuml;8&#8;&#19;&#2;&#19
;&#3;&#19;&#1;&yuml;&#1;&#1;&laquo;</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="etc/">etc/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="home/">home/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="lib/">lib/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="lib64/">lib64/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="media/">media/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="mnt/">mnt/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="opt/">opt/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="proc/">proc/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="root/">root/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="run/">run/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="sbin/">sbin/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="srv/">srv/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="sys/">sys/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="tmp/">tmp/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="usr/">usr/</A>
Feb 21 08:00:55 www ticketmon[53641]: <LI><A HREF="var/">var/</A>
Feb 21 08:00:55 www ticketmon[53641]: </UL>
Feb 21 08:00:55 www ticketmon[53641]: </BODY>
Feb 21 08:00:55 www ticketmon[53641]: </HTML>
Feb 21 08:00:55 www ticketmon[53641]: Can't connect to HTTP:80 (Name or service not known)
Feb 21 08:00:55 www ticketmon[53641]: Name or service not known at /usr/share/perl5/vendor_perl/LWP/Protocol/http.pm line 50.
Feb 21 08:00:55 www ticketmon[53741]: bash: line 7: $'\r': command not found
Feb 21 08:00:55 www ticketmon[53742]: bash: line 8: OPTIONS: command not found
Feb 21 08:00:55 www ticketmon[53743]: bash: line 9: $'\r': command not found
Feb 21 08:00:55 www ticketmon[53744]: bash: line 10: OPTIONS: command not found
Feb 21 08:00:55 www ticketmon[53745]: bash: line 11: $'\r': command not found
Feb 21 08:00:55 www ticketmon[947]: bash: line 12: syntax error near unexpected token `$'r\376\035\023\002\001\001\206\240\001\001\227''
Feb 21 08:00:55 www ticketmon[947]: bash: line 12: `◆(r◆#035#023#002#001◆◆#001◆|#036#006#001#001#007version#004bind#020#003#014#020#026#
003S#001O#003?G◆◆◆,◆◆`~◆◆◆{◆Ð◆W◆◆◆◆<=◆O◆#020n(#026#023'
Feb 21 08:00:55 www ticketmon[946]: write: Broken pipe
```

The relation of this to the acquisition of the /etc flag is questionable, though.

Later, a GET request was performed, which downloaded a file (deploy-all.sh) that does a multitude of malicious actions. This includes:

- Deploys a PAM sniffer
    - Everytime a user authenticates, a script is run that passes the user and their plaintext password to a remote server (http://49.10.219.164:8080)
- Creates an http server via python in /var/log
    - Allows for anyone to access any and all log files at any time
    - Cron job runs every 5 mins to protect this

- Wipes current SSH config and creates an SSH backdoor config
    - Allows root login via password and key, then restarts so changes take effect
    - Adds keys to root's `authorized_keys`
- Changes root's password to `taco`
- Makes `/etc/shadow` immutable
- Grabs Kerberos info (/root/krb.tgz and /tmp/krb*)
- Downloading, changing permissions of, and running a pamspy script.
    - Done via base64 decode
    - Allows anyone to look at output
    - https://github.com/citronneur/pamspy
    - Protected by crontab

24261	07:01:21.543750	89.65.43.50	49.10.219.164	HTTP	213 GET /deploy-all.sh HTTP/1.1

This script lays the basis for being able to capture the /etc AND /root flags by changing the root password and allowing root login via SSH. This may also be accomplished via path traversal using the python HTTP server in /var/log.

The initial GET request is believed to have been caused by the attacker creating an arbitrary session with admin privileges (or otherwise bypassing admin auth via broken access controls) by using the insecure secret key. This could have also been caused by user `taco`.

Remediation of the deploy-all.sh script is as follows:

- lsattr
    - root
    - -a /
    - /etc/pam.d
- chattr -iR
    - /root
    - /etc/shadow
    - /etc/ssh
    - /etc/pam.d
- Removing temp files
    - /tmp/credentials
    - /tmp/ps.tgz
    - /tmp/rootcrontab
- Remove added ssh auth keys and other malicious entries
    - /root/.ssh/authorized_keys
    - /etc/ssh/sshd-config.d/custom.conf
        - Change allow root login to no
        - Change passwordless/key-based to unallowed
- Removing scripts
    - /bin/pscript.sh
    - /opt/*

```
Feb 21 08:01:17 www systemd-logind[1758]: New session 385 of user taco.
Feb 21 08:01:17 www systemd[1]: Created slice User Slice of UID 1001.
Feb 21 08:01:17 www systemd[1]: Starting User Runtime Directory /run/user/1001...
Feb 21 08:01:17 www systemd[1]: Finished User Runtime Directory /run/user/1001.
Feb 21 08:01:17 www systemd[1]: Starting User Manager for UID 1001...
Feb 21 08:01:18 www systemd[53826]: Queued start job for default target Main User Target.
Feb 21 08:01:18 www systemd[53826]: Created slice User Application Slice.
Feb 21 08:01:18 www systemd[53826]: Started Mark boot as successful after the user session has run 2 minutes.
Feb 21 08:01:18 www systemd[53826]: Started Daily Cleanup of User's Temporary Directories.
Feb 21 08:01:18 www systemd[53826]: Reached target Paths.
Feb 21 08:01:18 www systemd[53826]: Reached target Timers.
Feb 21 08:01:18 www systemd[53826]: Starting D-Bus User Message Bus Socket...
Feb 21 08:01:18 www systemd[53826]: Starting Create User's Volatile Files and Directories...
Feb 21 08:01:18 www systemd[53826]: Finished Create User's Volatile Files and Directories.
Feb 21 08:01:18 www systemd[53826]: Listening on D-Bus User Message Bus Socket.
Feb 21 08:01:18 www systemd[53826]: Reached target Sockets.
Feb 21 08:01:18 www systemd[53826]: Reached target Basic System.
Feb 21 08:01:18 www systemd[53826]: Reached target Main User Target.
Feb 21 08:01:18 www systemd[53826]: Startup finished in 231ms.
Feb 21 08:01:18 www systemd[1]: Started User Manager for UID 1001.
Feb 21 08:01:18 www systemd[1]: Started Session 385 of User taco.
Feb 21 08:01:18 www systemd[1]: session-385.scope: Deactivated successfully.
Feb 21 08:01:18 www systemd-logind[1758]: Session 385 logged out. Waiting for processes to exit.
Feb 21 08:01:18 www systemd-logind[1758]: Removed session 385.
Feb 21 08:01:21 www systemd-logind[1758]: New session 387 of user root.
Feb 21 08:01:21 www systemd[1]: Started Session 387 of User root.
Feb 21 08:01:21 www systemd[1]: Stopping OpenSSH server daemon...
Feb 21 08:01:21 www systemd[1]: sshd.service: Deactivated successfully.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53738 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53739 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53774 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53775 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53791 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53792 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53793 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53795 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53807 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53808 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53810 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53811 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53813 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53814 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53816 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53817 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53818 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53819 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53873 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53874 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53876 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: sshd.service: Unit process 53877 (sshd) remains running after unit stopped.
Feb 21 08:01:21 www systemd[1]: Stopped OpenSSH server daemon.
Feb 21 08:01:21 www systemd[1]: sshd.service: Consumed 32.027s CPU time, 58.4M memory peak.
Feb 21 08:01:21 www systemd[1]: Stopped target sshd-keygen.target.
Feb 21 08:01:21 www systemd[1]: Stopping sshd-keygen.target...
Feb 21 08:01:21 www systemd[1]: OpenSSH ecdsa Server Key Generation was skipped because no trigger condition checks were met.
Feb 21 08:01:21 www systemd[1]: OpenSSH ed25519 Server Key Generation was skipped because no trigger condition checks were met.
Feb 21 08:01:21 www systemd[1]: OpenSSH rsa Server Key Generation was skipped because no trigger condition checks were met.
Feb 21 08:01:21 www systemd[1]: Reached target sshd-keygen.target.
```